

New Coworker

Vulnerability Management Procedures

Document owner: Engineering Leadership Version: 1.1 Effective: July 15, 2026 Review cycle: Annual

1. Purpose

These procedures define how New Coworker discovers, triages, remediates, and verifies security vulnerabilities across the platform that backs the **New Coworker OAuth** Zoom Marketplace application.

2. Continuous Discovery

Source	Tool / mechanism	Cadence
Static analysis (SAST)	GitHub CodeQL (javascript-typescript suite)	Every pull request and every push to <code>main</code>
Dynamic analysis (DAST)	OWASP ZAP baseline scan against production	Per release cycle and before Marketplace submissions
Dependency vulnerabilities	<code>npm audit</code> (production dependencies, high severity+ fails CI) in two independent workflows	Every pull request and push
Dependency freshness	Dependabot across all six npm workspaces and GitHub Actions	Weekly, with security advisories raised immediately
Secret exposure	GitGuardian scanning	Every pull request
Code review	Automated AI review (Cursor Bugbot) + human review; merge is blocked until every finding thread is resolved	Every pull request
External reports	security@newcoworker.com disclosure channel	Continuous

3. Triage and Severity

Severity	Definition	Response target	Remediation target
Critical	Exploitable exposure of customer data or credentials; auth bypass	Same day	Fix or mitigate within 48 hours
High	Significant weakness with plausible exploitation path	1 business day	7 days
Medium	Limited-impact weakness or defense-in-depth gap	3 business days	30 days
Low	Hardening opportunity, informational finding	Next planning cycle	90 days

Severity is assigned using CVSS as a guide, adjusted for actual exposure (e.g. whether the affected code path is reachable in production and whether RLS or encryption already contains the impact).

4. Remediation Workflow

- Findings are fixed in dedicated pull requests subject to the full CI gate: CodeQL, lint, type-check, dependency audit, the complete test suite at 100% coverage, integration tests, and code review with all threads resolved.
- Credential-related findings trigger immediate rotation of the affected secrets and revocation of the affected OAuth tokens (for Zoom, via `/oauth/revoke`) before root-cause work begins.
- Dependency advisories are remediated by Dependabot upgrade PRs; grouped minor/patch updates auto-merge only after the full CI gate passes, while major versions receive manual review.
- A regression test reproducing the vulnerability is required with every fix so the class of issue stays covered permanently.

5. Verification and Closure

- CodeQL and the dependency audit re-run automatically on the fix commit; a finding is closed only when the scanners pass and the fix is deployed to production.
- DAST scans are re-run after fixes to externally observable issues.
- Post-incident, a written root-cause summary records detection gap, fix, and the preventive control added.

6. Reporting

Open vulnerability counts and remediation aging are reviewed in the engineering cadence. External reporters receive acknowledgment within one business day and disposition on remediation.